ESTUDEMY • SEGURANÇA DA INFORMAÇÃO

Documento Técnico • Confidencial

Relatório de Análise de Riscos de Segurança

Avaliação técnica de vulnerabilidades de software, mapeamento de impacto x probabilidade, inventário de controles e plano de mitigação para a plataforma EstudeMy.

1. Critério de Avaliação e Metodologia de Riscos

A avaliação adota o modelo de matriz quantitativa padrão (ISO 31000 / OWASP Top 10), mensurando a severidade através do produto entre Impacto e Probabilidade.

Fórmula do Risco Inerente: `Risco = Impacto (I) × Probabilidade (P)`

1 a 10: Baixo	11 a 30: Médio	31 a 64: Alto	65 a 100: Crítico

Escala de Impactos (Magnitude de Severidade)

Magnitude	Descrição do Impacto Operacional / Negócio	I
Muito baixo	Degradação com impactos mínimos nos objetivos, prazos e metas.	1
Baixo	Degradação causando impactos pequenos e toleráveis nos objetivos.	2
Médio	Interrupção causando impactos significativos nos objetivos, porém recuperáveis.	5
Alto	Interrupção causando impactos de reversão muito difícil nos objetivos e reputação.	8
Muito alto	Paralisação geral causando impactos irreversíveis ou catastróficos.	10

Escala de Probabilidades (Frequência / Ocorrência)

Magnitude	Descrição da Possibilidade de Ocorrência	P
Muito baixa	Evento improvável de ocorrer; sem indícios conhecidos de exploração.	1
Baixa	Evento raro de ocorrer, podendo ocorrer de forma imprevista.	2
Média	Evento possível de ocorrer; dados apontam possibilidade moderada.	5
Alta	Evento provável de ocorrer; informações indicam de forma consistente.	8
Muito alta	Evento praticamente certo de ocorrer; indícios claros e inequívocos.	10

2. Matriz Consolidada de Riscos e Vulnerabilidades

Mapeamento completo dos 11 pontos de atenção, respectivos status de tratamento, ações mitigatórias e cálculo do Risco Inerente.

VULNERABILIDADE	TRATAMENTO	AÇÃO MITIGATÓRIA	RESP.	CÓD.	DESCRIÇÃO DO RISCO-CHAVE	I	P	RISCO	NÍVEL
SQL Injection	Mitigado	ORM, Prepared Statements e tipagem estrita via DTO em 100% das rotas.	Dev	RC01	Injeção SQL permitindo extração, alteração ou deleção de dados cadastrais/progresso.	8	1	8	Baixo
Cross-Site Scripting (XSS)	Em Mitigação	Sanitização de inputs, encoding nas saídas e política CSP ativa.	Dev	RC02	Scripts maliciosos em campos livres (perfil/fórum) executando no cliente para roubo de sessão.	5	5	25	Médio
Session Hijacking	Mitigado	JWT de curta duração + Refresh Tokens com rotação, MFA e expo-secure-store.	Dev	RC03	Interceptação de token JWT concedendo controle total sobre a conta sem senha.	8	2	16	Médio
Brute Force & Credential Stuffing	Em Mitigação	Rate Limiting progressivo por IP/conta, CAPTCHA adaptativo e hash forte (Bcrypt/Argon2).	Dev / Infra	RC04	Testes em massa de senhas comuns/vazadas na rota de login, causando invasões e sobrecarga.	5	8	40	Alto
Phishing e Eng. Social	Pendente	Treinamento corporativo, SPF/DKIM/DMARC no domínio e canal de denúncia.	SecOps / RH	RC05	Indução de alunos, professores ou admins a entregar credenciais por e-mails clonados.	8	5	40	Alto
IDOR (Insecure Direct Object Ref.)	Pendente	Validação de ownership (autorização a nível de objeto) no backend e adoção de UUIDs.	Dev	RC06	Acesso ou edição indevida de dados de terceiros alterando IDs na URL sem checagem de posse.	8	8	64	Alto
Privilege Escalation	Pendente	RBAC rigoroso no backend, validação por middleware e bloqueio de mass assignment.	Dev	RC07	Aluno alterando perfil para obter privilégios de Professor ou Administrador do sistema.	10	2	20	Médio
DDoS (Denial of Service)	Em Mitigação	WAF com mitigação anti-DDoS (Cloudflare), rate limiting e autoscaling de containers.	Infra	RC08	Inundação de tráfego tornando os serviços indisponíveis em provas e horários de pico.	5	5	25	Médio
Race Condition	Em Mitigação	Transações ACID com lock pessimista (FOR UPDATE) e restrições de unicidade (UNIQUE).	Dev	RC09	Requisições paralelas simultâneas duplicando moedas, vidas ou recompensas de gamificação.	2	5	10	Baixo
Data Exposure	Pendente	TLS 1.3, filtragem de DTOs nas respostas e supressão de stack traces em produção.	Dev / SecOps	RC10	Vazamento acidental de dados pessoais (PII) em logs de erro ou payloads da API (LGPD).	8	5	40	Alto
Directory Traversal	Pendente	Sanitização estrita com path.basename() e armazenamento em bucket seguro na nuvem (S3).	Dev	RC11	Manipulação de caminhos (../../) para leitura não autorizada de arquivos .env ou código-fonte.	10	2	20	Médio

3. Detalhamento e Justificativas Técnicas (Itens 1 a 6)

Análise profunda de cada vetor de ataque, justificativa de notas de impacto/probabilidade e plano de mitigação.

1. SQL Injection (RC01)

Risco: 8 (Baixo)

Justificativa: Impacto Alto (8) devido à capacidade de comprometimento massivo do banco de dados. Probabilidade Muito Baixa (1) com o uso consistente de ORMs e prepared statements.

Ação Prática: Proibir concatenação manual de SQL; aplicar validação de tipos via DTO/Zod e manter linter de segurança ativo no CI/CD.

2. Cross-Site Scripting — XSS (RC02)

Risco: 25 (Médio)

Justificativa: Impacto Médio (5) causando roubo de sessão ou defacement. Probabilidade Média (5) comum em campos de texto livre (chat, comentários ou bio).

Ação Prática: Sanitizar entradas com DOMPurify; aplicar escape automático nas views e reforçar cabeçalhos Content-Security-Policy (CSP).

3. Session Hijacking (RC03)

Risco: 16 (Médio)

Justificativa: Impacto Alto (8) por permitir personificação total sem conhecimento de senha. Probabilidade Baixa (2) devido a HTTPS compulsório e expo-secure-store.

Ação Prática: Rotação ativa de Refresh Tokens, revogação de tokens em blacklist no logout e suporte a MFA em contas administrativas.

4. Brute Force & Stuffing (RC04)

Risco: 40 (Alto)

Justificativa: Impacto Médio (5) com sequestro de contas e sobrecarga. Probabilidade Alta (8), visto que rotas de autenticação públicas sofrem varredura automatizada 24/7.

Ação Prática: Aplicar Rate Limiting rigoroso (ex.: 5 tentativas incorretas a cada 15 min), CAPTCHA progressivo e algoritmo Bcrypt/Argon2 com salt.

5. Phishing & Eng. Social (RC05)

Risco: 40 (Alto)

Justificativa: Impacto Alto (8) se comprometer credenciais de administradores ou professores. Probabilidade Média (5), explorando o elo humano frágil.

Ação Prática: Campanhas internas de simulação e conscientização; configuração estrita de SPF, DKIM e DMARC no DNS do domínio corporativo.

6. IDOR (RC06)

Risco: 64 (Alto - Crítico)

Justificativa: Impacto Alto (8) violando a LGPD ao expor dados e notas de terceiros. Probabilidade Alta (8) em APIs que recebem IDs sem checar posse do recurso.

Ação Prática: Validar que `req.user.id === resource.ownerId` em todo endpoint antes de responder; migrar IDs sequenciais para UUID v4.

3. Detalhamento e Justificativas Técnicas (Itens 7 a 11)

Continuação da análise técnica de vulnerabilidades e seus respectivos controles.

7. Privilege Escalation (RC07)

Risco: 20 (Médio)

Justificativa: Impacto Muito Alto (10) caso um aluno adquira permissões de administrador. Probabilidade Baixa (2) com RBAC centralizado no servidor.

Ação Prática: Proibir `mass assignment` (bloquear envio de campos `role` ou `isAdmin` no body) e validar papéis em middleware backend seguro.

8. DDoS (RC08)

Risco: 25 (Médio)

Justificativa: Impacto Médio (5) com indisponibilidade recuperável. Probabilidade Média (5) devido à disponibilidade de ferramentas públicas de estresse.

Ação Prática: Proteger DNS e borda com Cloudflare/WAF, ativar rate limit por IP e habilitar autoscaling de instâncias nos servidores.

9. Race Condition (RC09)

Risco: 10 (Baixo)

Justificativa: Impacto Baixo (2) atingindo pontuações gamificadas (moedas/XP). Probabilidade Média (5) se não houver trava concorrente nos endpoints.

Ação Prática: Utilizar transações ACID com locks pessimistas no banco de dados (`FOR UPDATE`) ou filas redis atômicas para entrega de premiações.

10. Data Exposure (RC10)

Risco: 40 (Alto)

Justificativa: Impacto Alto (8) devido a multas da LGPD e quebra de sigilo. Probabilidade Média (5) comum em APIs que serializam entidades cruas.

Ação Prática: Aplicar DTOs para excluir senhas/dados sensíveis do JSON de resposta; desativar stack traces de erro detalhados em ambiente produtivo.

11. Directory Traversal (RC11)

Risco: 20 (Médio)

Justificativa: Impacto Muito Alto (10) por exposição potencial de variáveis de ambiente (.env). Probabilidade Baixa (2) com storage em nuvem.

Ação Prática: Sanitizar caminhos com `path.basename()`; proibir parâmetros de arquivo que contenham `../` e priorizar buckets gerenciados (S3).

4. Priorização de Tratamento Recomendada (Plano de Resposta)

Classificação cronológica das ações mitigatórias baseada no Nível de Risco Inerente para alocação de equipe.

🔥 RISCO ALTO (Tratar Imediatamente / Sprint Atual) — Pontuação: 31 a 64

1º. IDOR (RC06) — Insecure Direct Object References	Score: 64
2º. Data Exposure (RC10) — Exposição Indevida de Dados Pessoais	Score: 40
3º. Brute Force & Stuffing (RC04) — Ataques Automatizados de Credenciais	Score: 40
4º. Phishing e Engenharia Social (RC05) — Vetores Sociais e Clonagem	Score: 40

⚠️ RISCO MÉDIO (Planejar para Próximos Sprints / Monitorar) — Pontuação: 11 a 30

5º. Cross-Site Scripting - XSS (RC02) — Sanitização e CSP	Score: 25
6º. DDoS (RC08) — Proteção de Infraestrutura e Borda	Score: 25
7º. Privilege Escalation (RC07) — RBAC e Proteção Mass Assignment	Score: 20
8º. Directory Traversal (RC11) — Sanitização de Caminhos de Arquivo	Score: 20
9º. Session Hijacking (RC03) — Rotação de Tokens e Armazenamento Seguro	Score: 16

✅ RISCO BAIXO (Manter Controles Ativos / Backlog de Melhoria) — Pontuação: 1 a 10

10º. Race Condition (RC09) — Transações e Bloqueio Concorrente	Score: 10
11º. SQL Injection (RC01) — ORM e Queries Parametrizadas	Score: 8